

DPDP COMPLIANCE AUDIT

documenso

Digital Personal Data Protection Act 2023



Grade C — Needs Work

Scanned: 08 April 2026

Files indexed: 1662

Languages: TypeScript, React, Next.js, Hono, TRPC, Tailwind CSS

CONFIDENTIAL — Internal Use Only

DPDP Compliance Scan Report

The application collects user credentials, profile information, document content, and recipient details. The primary risk surface lies in the handling of sensitive document content and recipient PII during the signing and distribution process, with potential for unauthorized access or data breaches.

Total findings: 22

HIGH: 4

MEDIUM: 4

INFO: 3

PASS: 8

Tech Stack: TypeScript, React, Next.js, Hono, TRPC

Risk Profile: The application collects user credentials, profile information, document content, and recipient details. The primary risk surface lies in the handling of sensitive document content and recipient PII during the signing and distribution process, with potential for unauthorized access or data breaches.

Compliance score by section

DPDP Section	Weight	Score	Status
Section 6	22	22/22 (100%)	PASS
Section 6(6)	8	8/8 (100%)	PASS
Section 8(1)	18	0/18 (0%)	FAIL
Section 8	10	7.0/10 (70%)	WARN
Section 8(3)	8	8/8 (100%)	PASS
Section 8(4)	8	6.8/8 (85%)	PASS
Section 8(6)	8	5.6/8 (70%)	WARN
Section 9	6	6/6 (100%)	PASS
Section 11	6	0/6 (0%)	FAIL
Section 16	4	0/4 (0%)	FAIL
Section 5	2	2/2 (100%)	PASS
Section 13 — Grievance Redressal	4	2.0/4 (50%)	WARN

Estimated Total Remediation Effort: 3.2–11.9 engineering days

Data Flow Analysis

The following PII flow signals were inferred via static analysis (import/call adjacency). These are heuristic code-path chains, not proven runtime traces. Use them to guide developer review (confirm actual request → handler → service → database paths in your app).

Flow 1: Analytics SDK

PII fields: email, pii_field

envelope-signing-complete-dialog.tsx → use-analytics.ts

Flow 2: Analytics SDK

PII fields: email, password, address

signup.tsx → use-analytics.ts

Flow 3: Application Logs

PII fields: email

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts

Flow 4: Application Logs

PII fields: email

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts → hono.ts → implementation.ts

Flow 5: Application Logs

PII fields: email, address

envelope-editor-fields-page.tsx → ai-field-detection-dialog.tsx → detect-fields.ts → hono.ts → implementation.ts → authenticated.ts

Rule	Section	Severity	File
CROSS_BORDER_TRANSFER_RISK	Section 16 — Cross-Border Transfer	HIGH	packages/lib/universal/get-ip-address.ts
PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT	Section 6 — Consent / Section 5 — Purpose Limitation	HIGH	packages/lib/client-only/hooks/use-analytics.ts
GRIEVANCE_OFFICER_MISSING	Section 13 — Grievance Redressal	MEDIUM	N/A
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	HIGH	packages/lib/jobs/definitions/internal/sync-email-domains.handler.ts
PLAINTEXT_PII_IN_LOGS	Section 8(1) — Security	MEDIUM	packages/lib/server-only/user/service-accounts/legacy-service-account.ts
NO_ERROR_HANDLING_IN_AUTH	Section 8(6) — Breach	MEDIUM	apps/remix/app/routes/_authenticated+/admin+/documents_index.tsx
INCOMPLETE_DELETION_COVERAGE	Section 8 — Data Principal Rights	MEDIUM	N/A
AUDIT_TRAIL_PARTIAL	Section 8(4) — Audit Trail	LOW	apps/remix/app/routes/_internal+/_htmltopdf+/audit-log.tsx
DATA_PORTABILITY_MISSING	Section 11 — Data Portability	LOW	N/A
CONSENT_MISSING	Section 6 — Consent	LOW	MULTIPLE
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	packages/trpc/server/webhook-router/schema.ts
INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	apps/remix/app/routes/embed+/playground.tsx

INTERNAL_ROUTE_PII_ACCESS	Section 7 — Legitimate Use	INFO	packages/trpc/server/enterprise-router/update-organisation-authentication-portal
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/components/general/document/document-edit-form.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	packages/auth/server/index.ts
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/routes/_unauthenticated+/o.\$orgUrl.signIn.tsx
CONSENT_PRESENT	Section 6 — Consent	PASS	apps/remix/app/components/tables/inbox-table.tsx
CONSENT_WITHDRAWAL_PRESENT	Section 6(6) — Consent Withdrawal	PASS	apps/remix/app/components/dialogs/account-delete-dialog.tsx
DELETION_MECHANISM_PRESENT	Section 8 — Data Principal Rights	PASS	N/A
BREACH_INDICATORS_ADEQUATE	Section 8(6) — Breach	PASS	N/A
DATA_ACCESS_PRESENT	Section 11 — Right to Access	PASS	packages/api/hono.ts
DEEP_REVIEW_VALIDATED	Section 11	HIGH	apps/remix/app/entry.client.tsx

30-Day Remediation Roadmap

The following plan prioritises findings by severity and estimated effort. Complete Week 1 items before your next security review.

Week 1 — Critical (11–39 hours)

Fix immediately — these represent the highest legal exposure.

- Cross Border Transfer Risk — universal/get-ip-address.ts (4–12 hrs)
- Pii Flow To Analytics Without Consent — hooks/use-analytics.ts (4–16 hrs)
- Plaintext Pii In Logs — internal/sync-email-domains.handler.ts (1–3 hrs)
- Deep Review Validated — app/entry.client.tsx (2–8 hrs)

Week 2 — High Priority (5–18 hours)

Address within 2 weeks — short fixes with significant compliance impact.

- Grievance Officer Missing (1–4 hrs)
- Plaintext Pii In Logs — service-accounts/legacy-service-account.ts (1–3 hrs)
- No Error Handling In Auth — admin+/documents._index.tsx (1–3 hrs)

■ Incomplete Deletion Coverage (2–8 hrs)

Week 4 — Advisory (10–38 hours)

Address before next compliance review.

- Audit Trail Partial — [__htmltopdf]/+audit-log.tsx (2–8 hrs)
- Data Portability Missing (2–8 hrs)
- Consent Missing — MULTIPLE (6–22 hrs)

Total estimated remediation effort: 26–95 hours (3.2–11.9 engineering days)

Details

Finding 1 of 22

[Section 16 — Cross-Border Transfer]

1. [HIGH] CROSS_BORDER_TRANSFER_RISK — packages / lib / universal / get-ip-address.ts:31

Evidence snippet: // Check for True-Client-IP (Akamai and Cloudflare)

Estimated fix time: 4–12 hours

Foreign cloud storage/CDN detected with PII models in repo. Cross-border transfer risk.

Risk:

The application processes recipient email addresses, which are considered PII. If these recipients are outside of the EEA/UK, this constitutes a cross-border transfer. Without appropriate safeguards, this poses a risk of non-compliance with DPDP Section 16.

Fix:

1. Implement data transfer impact assessments (DTIAs) for all cross-border transfers of recipient email addresses.
2. Ensure appropriate transfer mechanisms are in place, such as Standard Contractual Clauses (SCCs) or Binding Corporate Rules (BCRs), if transferring data outside of the EEA/UK.
3. Review the 'detect-recipients' functionality to determine if recipient email addresses are being stored or processed in a way that constitutes a cross-border transfer.
4. If recipient data is being sent to third-party services located outside the EEA/UK, verify that those services have adequate data protection measures in place.

DPDP:

Section 16 — Cross-Border Transfer

Example:

```
import { z } from 'zod'; export const ZDetectedRecipientSchema = z.object({ name:
z.string().optional(), email: z.string().email(), // PII detected role: z.string().optional(),
}); export const ZDetectedRecipientsSchema = z.object({ recipients:
z.array(ZDetectedRecipientSchema), });
```

Finding 2 of 22

[Section 6 — Consent / Section 5 — Purpose Limitation]

2. [HIGH] PII_FLOW_TO_ANALYTICS_WITHOUT_CONSENT — packages / lib / client-only / hooks / use-analytics.ts:37

Evidence snippet: Defines 'startSessionRecording' which interacts with PostHog's session recording feature.

Estimated fix time: 4–16 hours

PII flows from envelope-signing/envelope-signing-complete-dialog.tsx to analytics service (hooks/use-analytics.ts) through 1 intermediate file(s). No analytics-specific consent detected on this flow path. DPDP Section 6 requires explicit consent for analytics processing separate from functional/auth consent.

Risk:

The application uses PostHog for analytics, which may process user data. Without explicit consent for analytics processing, this violates DPDP Section 6 and Section 5, as data is being collected for purposes beyond core service functionality without user agreement.

Fix:

1. Implement a clear and granular consent mechanism for analytics tracking, distinct from functional consent.
2. Ensure that analytics tracking (e.g., via `posthog.capture`) is only initiated after the user has provided explicit consent.
3. Update the `useAnalytics` hook to conditionally enable PostHog functionality based on user consent status.
4. Provide users with an easy way to withdraw their consent for analytics tracking at any time.

DPDP:

Section 6 — Consent / Section 5 — Purpose Limitation

Example:

```
import { posthog } from 'posthog-js'; import { useConsent } from
'@documenso/lib/client-only/hooks/use-consent'; // Assuming a consent hook exists export
function useAnalytics() { const { analyticsConsentGiven } = useConsent(); // Get consent
status const isPostHogEnabled = extractPostHogConfig() && analyticsConsentGiven; const capture
= (event: string, properties?: Record<string, unknown>) => { if (!isPostHogEnabled) return;
posthog.capture(event, properties); }; // ... other functions ... return { capture,
captureException, startSessionRecording, stopSessionRecording }; }
```

Finding 3 of 22

[Section 13 — Grievance Redressal]

3. [MEDIUM] GRIEVANCE_OFFICER_MISSING — N / A:1**Evidence snippet:** Provides utility functions for handling Cross-Origin Resource Sharing (CORS).**Estimated fix time:** 1–4 hours

No compliant Grievance Officer / DPO publication found. A PASS requires grievance-related text or a dedicated route ****and**** a contact email or dedicated grievance/DPO URL. Tiny repos without a grievance route are not marked PASS.

Risk:

The absence of a designated Grievance Officer or Data Protection Officer (DPO) contact point means individuals have no clear channel to address concerns or exercise their data subject rights, increasing the risk of unresolved grievances and non-compliance with DPDP Section 13.

Fix:

1. Create a new route (e.g., `/compliance/grievance-officer``) that clearly displays the contact information for the Grievance Officer or DPO.
2. Add a dedicated contact email address (e.g., ``dpo@example.com`` or ``grievance@example.com``) to a publicly accessible page, such as a privacy policy or contact page.
3. Ensure the contact information is easily discoverable by users, for example, by linking to it from the website footer or a dedicated 'Contact Us' page.
4. Publish the name and contact details of the designated Grievance Officer or DPO on the company website.

DPDP:

Section 13 — Grievance Redressal

Example:

```
import { defineConfig } from 'vite'; export default defineConfig({ // ... other config
plugins: [ // ... other plugins { name: 'add-grievance-officer-info' }, // Placeholder for a
plugin that might inject info ], // Example of adding a route in a framework like Express: //
app.get('/grievance-officer', (req, res) => { // res.json({ email: 'dpo@example.com', name:
'Jane Doe' }); // }); });
```

Finding 4 of 22

[Section 8(1) — Security]

4. [HIGH] PLAINTEXT_PII_IN_LOGS — packages / lib / jobs / definitions / internal / sync-email-domains.handler.ts:30**Evidence snippet:** io.logger.info('No pending email domains to sync');**Estimated fix time:** 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Risk:

The finding indicates that PII keywords appear in logging calls, suggesting that sensitive personal data might be logged in plaintext. This is a direct violation of DPDP Section 8(1) regarding data security, potentially exposing PII if logs are compromised or accessed inappropriately.

Fix:

1. Review all logging statements within `sync-email-domains.handler.ts` to identify any instances where PII might be inadvertently included.
2. Modify logging statements to exclude or mask PII fields before they are written to logs. For example, replace `logger.info('User email: \${user.email}') with `logger.info('User email: [REDACTED]')` or similar).
3. Implement a PII detection mechanism in the logging pipeline to automatically flag or redact sensitive information before it's persisted.
4. Ensure that log levels are configured appropriately, with sensitive information only logged at the DEBUG level and only when absolutely necessary for debugging.

DPDP:

Section 8(1) — Security

Example:

```
import logger from '@documenso/lib/server-only/logger'; // ... inside the handler function ...
const emailDomain = 'example.com'; // Assume this is sensitive data // Instead of: //
logger.info('Processing email domain: ${emailDomain}'); // Use: logger.info('Processing email
domain: [REDACTED]'); // Masking PII // Or if you need to log it for debugging, use a lower
level and ensure access is restricted: // logger.debug('Processing email domain:
${emailDomain}');
```


Finding 5 of 22

[Section 8(1) — Security]

5. [MEDIUM] PLAINTEXT_PII_IN_LOGS — packages / lib / server-only / user / service-accounts / legacy-service-account.ts:23

Evidence snippet: console.log(`Migrating legacy service account to new email: \${legacyServiceAccountEmail()}`);

Estimated fix time: 1–3 hours

PII keyword appears in logging call. Personal data may be written to logs in plaintext.

Risk:

The rule engine flagged a potential issue with plaintext PII in logs. However, the provided code snippet does not contain any logging calls or PII fields that would confirm this violation.

Therefore, the risk is not confirmed by the evidence.

Fix:

1. Review the full codebase for any logging statements that might include PII.
2. Implement a mechanism to sanitize or mask PII before it is written to logs.
3. Ensure that log levels are configured appropriately to avoid excessive logging of sensitive data.

DPDP:

Section 8(1) — Security: Requires appropriate technical and organizational measures to protect personal data, including preventing unauthorized access and disclosure.

Example:

```
import logger from '@documenso/lib/server-only/logger'; function processUserData(user: { name: string; email: string }) { // Example: Masking PII before logging const maskedUser = { ...user, name: '***', email: '***' }; logger.info('Processing user data', { user: maskedUser }); }
```

Finding 6 of 22

[Section 8(6) — Breach]

6. [MEDIUM] NO_ERROR_HANDLING_IN_AUTH — apps / remix / app / routes / _authenticated+ / admin+ / documents._index.tsx:25

Evidence snippet: The loader function `loader` fetches license data but does not include a try-catch block to handle potential errors during data fetching.

Estimated fix time: 1–3 hours

Auth routes have no try/catch or try/except blocks. Errors may go unlogged.

Risk:

Authentication-related routes lack error handling, meaning that if an error occurs during request processing, it may not be logged or handled gracefully, potentially leading to uninformative error messages for users or administrators.

Fix:

1. Wrap the `LicenseClient.getInstance()?.getCachedLicense()` call in the `loader` function with a try-catch block to handle potential errors.
2. Add a try-catch block around any data fetching or processing logic within the `Claims` component's `useEffect` hook or other event handlers.
3. Implement centralized error handling for Remix routes to catch and log errors that occur during rendering or data loading.

DPDP:

Section 8(6) — Breach: Requires controllers and processors to implement appropriate technical and organizational measures to ensure the security of personal data, including measures to prevent, and to notify the relevant supervisory authority and the data subject in case of, a personal data breach.

Example:

```
export async function loader() { try { const licenseData = await
LicenseClient.getInstance()?.getCachedLicense(); return { licenseFlags:
licenseData?.license?.flags, }; } catch (error) { console.error('Error fetching license
data:', error); // Depending on requirements, you might want to return an error response // or
a default value. return { licenseFlags: null }; } }
```

Finding 7 of 22

[Section 8 — Data Principal Rights]

7. [MEDIUM] INCOMPLETE_DELETION_COVERAGE — N / A**Estimated fix time:** 2–8 hours

Deletion mechanism detected but may not cover all PII storage. Uncovered files: packages/auth/server/routes/email-password.ts, packages/ee/server-only/lib/send-organisation-account-link-confirmation-email.ts, packages/lib/server-only/2fa/email/send-2fa-token-email.ts, packages/lib/server-only/auth/create-passkey-registration-options.ts, packages/lib/server-only/document/complete-document-with-token.ts. DPDP Section 8 requires complete erasure of all personal data across all systems when a user requests deletion.

Risk:

The absence of a comprehensive deletion mechanism means that personal data might persist in the system even after a user requests deletion, violating data minimization and erasure principles under DPDP Section 8.

Fix:

1. Implement a centralized data deletion service that identifies and removes PII across all specified storage locations.
2. Integrate this deletion service into user account deletion workflows.
3. Add unit and integration tests to verify that PII is completely removed from all relevant data stores.
4. Consider implementing a data retention policy and automated cleanup jobs for any data that does not require indefinite storage.

DPDP:

Section 8 — Data Principal Rights: Mandates that data controllers ensure the rights of data principals, including the right to erasure ('right to be forgotten').

Example:

```
import { db } from '@documenso/lib/server-only/db'; async function deleteUserPII(userId: string): Promise<void> { // Example: Deleting user data from a database table await db.user.deleteMany({ where: { id: userId } }); // Add calls to delete data from other services/storage as needed console.log(`PII for user ${userId} deleted successfully.`); }
```

Finding 8 of 22

[Section 8(4) — Audit Trail]

8. [LOW] AUDIT_TRAIL_PARTIAL — apps / remix / app / routes / _internal+ / [__htmltopdf]+ / audit-log.tsx**Estimated fix time:** 2–8 hours

Partial audit trail detected. Found: access logging, change tracking. Missing: dedicated audit model/table. DPDP Section 8(4) requires a structured audit trail with user identity, timestamp, action, and data accessed. A dedicated audit log table is required for proper compliance.

Risk:

This appears to be an internal audit/compliance view. Verify that (1) access is restricted to authorized staff only, and (2) the purpose is documented (e.g. legal obligation or compliance). If so, no consent mechanism is required for this processing.

Fix:

1. Document the legal basis for processing personal data in the audit log, referencing DPDP Section 7 legitimate use cases.
2. Verify that access to the audit log view is strictly controlled and limited to authorized personnel.
3. Ensure that the audit log only contains data necessary for compliance and security monitoring purposes.

DPDP:

Section 8(4) — Audit Trail: Requires controllers to maintain an audit trail of processing operations involving personal data.

Example:

```
import { requireAdmin } from '@documenso/auth/server/lib/utils/require-admin'; export async
function loader({ request }: { request: Request }) { await requireAdmin(request); // Ensure
only admins can access this route // Fetch and return audit log data return {}; }
```

Finding 9 of 22

[Section 11 — Data Portability]

9. [LOW] DATA_PORTABILITY_MISSING — N / A

Estimated fix time: 2–8 hours

No data export or portability endpoint detected. DPDP Section 11 requires Data Fiduciaries to provide personal data in a commonly used, machine-readable format upon request.

Risk:

The absence of a data export feature means users cannot obtain a copy of their personal data in a machine-readable format, which is a requirement under DPDP Section 11.

Fix:

1. Implement an API endpoint (e.g., `/api/v1/data-export`) that, upon authenticated user request, retrieves their personal data.
2. Format the retrieved personal data into a commonly used, machine-readable format such as JSON or CSV.
3. Provide a mechanism for the user to download this data file, ensuring the process is secure and authenticated.
4. Document the data export process and its availability to users in the privacy policy.

DPDP:

Section 11(1) — Data Fiduciaries shall, upon request by the Data Principal, provide to the Data Principal personal data being processed about them in a commonly used and machine-readable format.

Example:

```
import express from 'express'; import fs from 'fs'; import path from 'path'; const router =
express.Router(); router.get('/data-export', async (req, res) => { const userId = req.user.id;
// Assuming user is authenticated const userData = await fetchUserData(userId); // Fetch user
data from DB const jsonData = JSON.stringify(userData, null, 2);
fs.writeFileSync(path.join(__dirname, `user-data-${userId}.json`), jsonData);
res.download(path.join(__dirname, `user-data-${userId}.json`)); }); export default router;
```

Finding 10 of 22

[Section 6 — Consent]

10. [LOW] CONSENT_MISSING — MULTIPLE:20**Evidence snippet:** import { zEmail } from '@documenso/lib/utis/zod';**Estimated fix time:** 6–22 hours**Affected files (7):**

- apps/remix/app/components/forms/signin.tsx
- packages/lib/server-only/webhooks/zapier/list-documents.ts
- apps/remix/app/components/general/document/document-recipient-link-copy-dialog.tsx
- apps/remix/app/components/forms/signup.tsx
- packages/ui/primitives/document-flow/field-item.tsx
- packages/ui/primitives/document-flow/field-items-advanced-settings/email-field.tsx
- ... and 1 more files

Authentication form collects email for login/signup. Detected in 7 files: signin.tsx, list-documents.ts, document-recipient-link-copy-dialog.tsx, signup.tsx and 3 more

Risk:

Collecting email and password for login without explicit consent violates DPDP Section 6, as it processes personal data without a clear, informed agreement from the user for this specific purpose.

Fix:

1. Add a checkbox or clear statement during the signup process that requires explicit user consent for collecting and processing email and password for login purposes.
2. Ensure the consent mechanism is granular, allowing users to opt-in specifically for authentication.
3. Store the consent status along with user data.
4. Update the login form to clearly state that logging in implies agreement to the terms and privacy policy, if consent is implied by login.

DPDP:

Section 6(1) — Consent for the processing of personal data shall be obtained in clear and affirmative manner from the Data Principal.

Example:

```
import React from 'react'; import { Checkbox } from '@documenso/ui/primitives/checkbox'; //
... inside your signup form component <FormField control={form.control} name="consentToTerms"
render={({ field }) => ( <FormItem className="flex flex-row items-start space-x-3 space-y-0
p-4"> <FormControl> <Checkbox checked={field.value} onCheckedChange={field.onChange} />
</FormControl> <div className="space-y-1 leading-none"> <FormLabel> I agree to the <a
href="/terms" target="_blank">Terms of Service</a> and <a href="/privacy"
target="_blank">Privacy Policy</a>. </FormLabel> </div> </FormItem> )} />
```

Finding 11 of 22

[Section 7 — Legitimate Use]

11. [INFO] INTERNAL_ROUTE_PII_ACCESS — packages / trpc / server / webhook-router / schema.ts

Internal file (schema.ts) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 12 of 22

[Section 7 — Legitimate Use]

12. [INFO] INTERNAL_ROUTE_PII_ACCESS — apps / remix / app / routes / embed+ / playground.tsx

Internal file (playground.tsx) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 13 of 22

[Section 7 — Legitimate Use]

13. [INFO] INTERNAL_ROUTE_PII_ACCESS — packages / trpc / server / enterprise-router / update-organisation-authentication-portal.types.ts

Internal file (update-organisation-authentication-portal.types.ts) accesses PII. Verify access is restricted to authorised contexts and PII is not exposed to logs or error responses.

Finding 14 of 22

[Section 6 — Consent]

14. [PASS] CONSENT_PRESENT — apps / remix / app / components / general / document / document-edit-form.tsx

Consent covered via imported module: packages/auth/server/lib/utls/get-session.ts, packages/lib/client-only/providers/session.tsx

Finding 15 of 22

[Section 6 — Consent]

15. [PASS] CONSENT_PRESENT — packages / auth / server / index.ts

Consent covered via imported module: packages/auth/server/lib/utls/get-session.ts, packages/lib/client-only/providers/session.tsx

Finding 16 of 22

[Section 6 — Consent]

16. [PASS] CONSENT_PRESENT — apps / remix / app / routes / _unauthenticated+ / o.\$orgUrl.signin.tsx

Framework auth/consent middleware detected in this file.

Finding 17 of 22

[Section 6 — Consent]

17. [PASS] CONSENT_PRESENT — apps / remix / app / components / tables / inbox-table.tsx

Consent covered via imported module: packages/auth/server/lib/utls/get-session.ts, packages/lib/client-only/providers/session.tsx

Finding 18 of 22

[Section 6(6) — Consent Withdrawal]

18. [PASS] CONSENT_WITHDRAWAL_PRESENT — apps / remix / app / components / dialogs / account-delete-dialog.tsx

Consent withdrawal mechanism detected. Found in:
apps/remix/app/components/dialogs/account-delete-dialog.tsx (line 25)

Finding 19 of 22

[Section 8 — Data Principal Rights]

19. [PASS] DELETION_MECHANISM_PRESENT — N / A

Data deletion mechanism detected. Found 0 deletion endpoint(s) and 137 deletion signal(s). Cascade delete patterns detected.

Finding 20 of 22

[Section 8(6) — Breach]

20. [PASS] BREACH_INDICATORS_ADEQUATE — N / A

Logging and/or breach alerting present.

Finding 21 of 22

[Section 11 — Right to Access]

21. [PASS] DATA_ACCESS_PRESENT — packages / api / hono.ts

Data access endpoint detected for authenticated users.

Finding 22 of 22

[Section 11]

22. [HIGH] DEEP_REVIEW_VALIDATED — apps / remix / app / entry.client.tsx

Estimated fix time: 2–8 hours

The `PosthogInit` component initializes PostHog on the client-side using `posthog.init`. The `capture\_exceptions` flag is set to `true`. This means that errors occurring in the browser will be captured and sent to PostHog. However, there is no explicit user consent mechanism shown in this file or related components to allow for this tracking, which may include PII if exceptions contain it.

AI-Identified Compliance Gaps

The following gaps were identified by AI analysis and cross-validated. These are advisory observations, not verified rule violations. Human review is required before acting on these findings.

[AI-INFERRED] Missing audit trail for data access

Confidence: 55%

Section 8(4) — Audit Trail

The `apps/remix/app/components/tables/internal-audit-log-table.tsx` and `apps/remix/app/components/tables/document-logs-table.tsx` suggest an audit log exists, but there's no explicit mention or code snippet showing that personal data access events (as required by Section 8(4)) are logged. The current logs might be too general.

Recommendation: Implement specific logging for all read operations on personal data, ensuring these logs capture user ID, data accessed, timestamp, and purpose. Review `internal-audit-log-table.tsx` and `document-logs-table.tsx` to ensure they can accommodate and display this granular access data.

[AI-INFERRED] Unclear purpose for AI-detected fields

Confidence: 30%

Section 5 — Purpose Limitation

The data flow mentions `AI-detected fields collected via POST /api/ai/detect-fields` and `AI-detected recipients collected via POST /api/ai/detect-recipients`. The purpose for collecting and storing these AI-detected fields and recipients is not explicitly defined or justified, potentially violating Section 5's purpose limitation principle if not for a clearly stated, legitimate purpose.

Recommendation: Add explicit documentation or code comments within the `/api/ai/detect-fields` and `/api/ai/detect-recipients` endpoints to clearly state the purpose for collecting and processing AI-detected data. Ensure this purpose is communicated to users if it involves personal data.

[AI-INFERRED] No age verification for account creation

Confidence: 60%

Section 9 — Children's Data

The `apps/remix/app/routes/\_unauthenticated+/signup.tsx` file handles user signup, collecting email, password, and name. There is no visible mechanism for verifying the age of users during signup, which is a requirement under Section 9 if the service is intended for or accessible by children.

Recommendation: Implement an age verification step during the signup process in `apps/remix/app/routes/\_unauthenticated+/signup.tsx`. This could involve a checkbox confirming the user is above a certain age, or a more robust age verification method if the service targets or may be used by minors.

[AI-INFERRED] DPO contact not exposed

Confidence: 20%

Section 10 — Data Protection Officer

There is no mention or code snippet in the provided context that suggests a Data Protection Officer (DPO) contact is made available to users or data subjects, as might be expected under Section 10 for certain organizations.

Recommendation: If a DPO is appointed, add contact information for the DPO in a publicly accessible location, such as a privacy policy page or a dedicated contact section within the application's settings or footer.

Deep Compliance Review

Overall Risk: CRITICAL

Critical DPDP risks exist due to the unconsented collection and transmission of PII and unique identifiers to third-party analytics services like PostHog. Sensitive data, including potential PII, is also exposed in client-side error logs and checkout URLs. The current implementation lacks explicit user consent mechanisms for tracking and analytics, creating a significant compliance gap.

Estimated remediation: 17 engineering day(s)

Most Critical Action: Implement a robust consent management system to obtain explicit user consent before initializing any third-party analytics or tracking services (e.g., PostHog) and before capturing any user data, including exceptions and telemetry IDs.

Layer Breakdown

Configuration & Secrets — 0 finding(s). The configuration files reviewed do not present any direct DPDP compliance risks. They primarily focus on code linting, formatting, internationalization, and build configurations. No sensitive data handling or PII processing logic is evident in these configuration files.

Data Models & Storage — 0 finding(s). The data models and storage layer defines schemas for document creation, retrieval, and management. It appears to correctly define fields and their types, including PII like email addresses. No direct DPDP compliance issues were identified within this schema definition file itself. However, it's crucial that the implementation consuming these schemas enforces consent and data minimization principles.

API Routes & Controllers — 2 finding(s). This component handles the creation of organizations and involves billing and plan selection. It relies on client-side form handling and TRPC mutations. The primary compliance concerns identified relate to the potential exposure of PII in URLs generated for checkout and in client-side error logging.

Authentication & Session — 3 finding(s). The authentication and session management layer appears to be largely functional, with session data being retrieved and used to protect authenticated routes. The primary areas for improvement relate to explicit session invalidation on logout and ensuring data freshness for user-specific contexts like organizations and teams. The admin panel's access control is noted as a potential area for enhanced security, though the core check is present.

Third-Party & PII Flows — 4 finding(s). This layer primarily deals with third-party integrations for analytics and telemetry. The main compliance concerns revolve around the implementation of consent for data collection and processing by these third parties, particularly PostHog. The current implementation appears to rely on feature flags rather than explicit user consent for enabling these services, which poses a significant DPDP risk. Additionally, the handling of unique identifiers in telemetry and the potential for sensitive data in exceptions require careful review.